

Azure IAM & Cloud Security Notes

Metadata

- **Topic:** Microsoft Entra Identity Governance — Entitlement Management
- **Date:** 2026-08-24
- **Source Material:** Microsoft Learn — "Plan, implement, and manage entitlements in Microsoft Entra ID"
- **Author/Creator:** Microsoft Learn

Executive Summary (The "So What?")

Entitlement management automates who gets access to what, for how long, and who has to approve it — instead of admins manually granting access one request at a time. It matters because the two biggest access risks in any org are people not knowing what to request (so they bug IT or an admin over-provisions "just in case"), and people keeping access long after they need it. Entitlement management directly targets both problems with time-limited, self-service, reviewable access.

Core Concepts & Architectural Blueprint

- **Key Concept 1: Catalog**
 - *Definition:* A container that groups related resources (groups, apps, SharePoint sites) and the access packages built from them. Lets non-admins ("catalog owners") manage their own slice of resources without full admin rights.
 - *Security Risk:* If catalog ownership is handed out too loosely, you've effectively delegated access-granting power outside IT's visibility.
- **Key Concept 2: Access Package**
 - *Definition:* A bundle of resource roles (e.g., "member of Marketing group" + "access to Marketing app") that a user requests as one unit, governed by a policy.
 - *Security Risk:* A poorly scoped access package (too many resources bundled together) means a user only needing one resource ends up with all of them.
- **Key Concept 3: Policy**
 - *Definition:* Rules attached to an access package defining who can request it, who approves, and how long access lasts before expiring. One access package can have multiple policies — e.g., one for internal employees, one for external/B2B users.
 - *Security Risk:* No expiration set = access that never gets reviewed or revoked, the classic "permission creep" problem.
- **Key Concept 4: Connected Organization**
 - *Definition:* An external tenant/domain you have an ongoing relationship with, so their users can be allowed to request your access packages (brought in automatically via Microsoft Entra B2B).
 - *Security Risk:* Connected orgs widen your attack surface — if the partner org's identity hygiene is weak, that risk flows into your directory via B2B guest accounts.
- **Key Concept 5: Terms of Use (ToU)**
 - *Definition:* A PDF-based agreement (e.g., EULA/contract) users must accept — enforced via Conditional Access — before they can access resources.
 - *Security Risk:* Not directly a technical control, but a compliance/legal one — missing ToU enforcement means no documented proof a user agreed to acceptable-use terms.

Common Cloud Misconfigurations & Attack Vectors

- **The Flaw:** No expiration policy set on an access package assignment
 - **Exploit Mechanism:** Access silently persists indefinitely — an employee who changes roles or leaves a project (or the org, if offboarding is incomplete) retains access no one is actively reviewing. This is exactly the "permission creep" the whole feature is designed to prevent.
 - **Remediation:** Always set a lifecycle/expiration duration on policies, and require periodic access reviews.
- **The Flaw:** External user lifecycle settings left on defaults without review
 - **Exploit Mechanism:** By default, an external (B2B guest) user who loses their last access package assignment is blocked from sign-in, and their guest account is auto-removed after 30 days — but only for accounts that were invited *through* entitlement management. Guests added other ways aren't covered, creating an inconsistent offboarding gap.
 - **Remediation:** Explicitly review "Manage the lifecycle of external users" settings and understand which guests are and aren't covered by the auto-removal behavior.
- **The Flaw:** Over-bundling resources into a single access package
 - **Exploit Mechanism:** A user requesting access for one legitimate reason (e.g., a SharePoint site) ends up also getting a security group and app assignment bundled in the same package — violating least privilege.
 - **Remediation:** Scope access packages tightly to a single project/purpose rather than bundling unrelated resources for convenience.

Simulated Lab / Proof of Concept

1. **Objective:** Create a catalog, add a resource to it, and understand how access packages/policies attach to it.
2. **Steps Taken:**
 - Step 1: Signed into Microsoft Entra admin center → ID Governance → Entitlement Management → Catalogs.
 - Step 2: Created a new catalog named "Marketing" with a description, left "Enabled" set to No initially.
 - Step 3: Added a resource (group/app/SharePoint site) to the catalog under Resources → + Add resources.
 - Step 4: Added a second catalog owner via Roles and administrators → + Add owner, to test delegation.
 - Step 5: Edited the catalog to set Enabled = Yes.
3. **Verification (PowerShell via Microsoft Graph):**

```
Connect-MgGraph -Scopes "EntitlementManagement.Read.All"
```

```
Select-MgProfile -Name "beta"
```

```
$accesspackage = Get-MgEntitlementManagementAccessPackage -DisplayNameEq "Marketing Campaign"
```

```
$assignments = Get-MgEntitlementManagementAccessPackageAssignment -AccessPackageId $accesspackage.Id -ExpandProperty target -All -ErrorAction Stop
```

\$assignments | ft Id,AssignmentState,TargetId,{\$_Target.DisplayName}

4. **Outcome:** Confirmed a catalog can be created, populated with resources, and delegated to a co-owner — the foundation an access package is later built on top of. Confirmed assignments can be queried programmatically for auditing, not just through the portal.

Key Vocabulary

- **Access Package:** A bundle of resources (groups, apps, sites) a user requests as one unit; lives inside a catalog.
- **Catalog:** A container of resources and access packages, used to delegate management to non-admins.
- **Policy:** Rules on an access package defining who can request, who approves, and how long access lasts.
- **Assignment:** The result of an approved request — the actual grant of access tied to a user, usually time-limited.
- **Connected Organization:** An external tenant/domain whose users can be allowed to request your access packages via B2B.
- **Terms of Use (ToU):** A PDF agreement enforced through Conditional Access that users must accept before getting access.
- **Sponsor:** An internal or external point-of-contact user associated with a connected organization.
- **Resource Role:** A specific permission level tied to a resource (e.g., group "member" vs. "owner").